SHIELD

Seu escudo digital

LAUDO DE ANÁLISE DE SEGURANÇA PASSIVA (DADOS PÚBLICOS)

Empresa	Laboratório Cidadão — Ariquemes/RO
Segmento	Laboratório de análises clínicas (dado de saúde)
Endereço analisado	exameslaboratoriocidadao.com.br
Data da análise	21/10/2026, 13h10 (horário de Rondônia)
Escopo	Somente informação pública (HTTP/HTTPS, DNS, certificado) Nenhum acesso autenticado ou tentativa de intrusão
Emitido por	Lorran Gustavo — SHIELD Cibersegurança, Ariquemes/RO

1. Resumo executivo

A análise passiva do site do Laboratório Cidadão, feita apenas com informação pública (o que qualquer navegador enxerga), encontrou dois problemas de severidade alta que afetam diretamente o paciente e a responsabilidade do laboratório sob a LGPD.

O primeiro: o site é entregue sem HTTPS. A página inicial abre em HTTP puro e o servidor não redireciona o visitante para a versão segura. Nessa mesma página está o formulário onde o paciente informa código e senha para consultar o resultado do exame. Em qualquer rede Wi-Fi aberta (lanchonete, aeroporto, recepção de clínica, rede compartilhada), esses campos trafegam sem criptografia e podem ser lidos por terceiros na mesma rede.

O segundo: o endereço seguro do domínio não abre o site do laboratório. Quem digita https://exameslaboratoriocidadao.com.br cai no painel de login do provedor de hospedagem (Plesk Obsidian 18.0.80). O paciente vê uma tela de servidor no lugar do laboratório, e o painel administrativo da hospedagem fica exposto na raiz do domínio.

Não houve invasão observada nem acesso a dados internos: tudo o que está neste laudo é observável por qualquer pessoa com um navegador.

2. Achados

Formulário de resultado do exame entregue sem HTTPS

ALTO

Requisição direta em 21/10/2026 13:10: http://exameslaboratoriocidadao.com.br/ responde 200 e NÃO redireciona para HTTPS. A página entrega o formulário de consulta de resultados com action="https://portal.worklabweb.com.br/resultados/1157" e os campos tbCodigo e tbSenha. O conteúdo (código e senha do paciente) é digitado em página servida sem TLS.

Impacto: Credencial de acesso a resultado de exame trafegando em texto claro. Interceptável em rede Wi-Fi pública. Dado de saúde é categoria especial na LGPD (art. 5º, II): o risco jurídico é o mais alto da lei.

Endereço HTTPS do domínio entrega o painel de hospedagem (Plesk)

ALTO

https://exameslaboratoriocidadao.com.br/ → 303 para /login.php → 303 para /login_up.php → 200 com título "Plesk Obsidian 18.0.80" (Server: Microsoft-IIS/10.0; X-Powered-By-Plesk: PleskWin).

Impacto: Paciente que digita o endereço seguro vê tela de administração do servidor. Exposição de superfície administrativa do provedor na raiz do domínio e dano de imagem na primeira impressão do site.

Certificado TLS apresentado não pertence ao domínio

MÉDIO

Certificado no 443: CN=*.hospedagemdesites.ws, emissor GlobalSign AlphaSSL CA 2025, válido até 28/11/2026.

Impacto: O nome não corresponde ao domínio do laboratório: navegadores exibem aviso de conexão não segura, o que reduz confiança do paciente e reforça o problema do item anterior.

Canal de contato em e-mail pessoal (Gmail) para dado de saúde MÉDIO

Único endereço de e-mail publicado no site: labcidadao@gmail.com.

Impacto: Falta de domínio corporativo e de política de uso para dado sensível. Não é falha técnica, é governança: dificulta rastreabilidade e resposta a incidente exigidas pela LGPD.

3. Exposição legal (LGPD)

• Art. 5º, II — dado de saúde é dado pessoal sensível; exige proteção reforçada.

• Art. 46 — o controlador deve adotar medidas de segurança técnicas e administrativas aptas a proteger os dados de acessos não autorizados e de situações acidentais de destruição, perda ou alteração. Servir formulário de credencial em HTTP não atende ao dispositivo.

• Art. 48 — incidente que possa acarretar risco relevante deve ser comunicado à ANPD e ao titular; a ausência de criptografia amplia o dever de comunicação.

• Art. 52 — sanções: advertência, multa simples de até 2% do faturamento do último exercício, limitada a R$ 50.000.000,00 por infração, além de publicização da infração e bloqueio dos dados.

4. Plano de correção

#	Ação	Prazo
1	Instalar certificado TLS válido para o próprio domínio (Let's Encrypt, gratuito) e apontar o vhost correto.	Imediato (até 48h)
2	Forçar redirecionamento 301 de http:// para https:// em todo o site, inclusive na página do formulário de resultados.	Imediato (até 48h)
3	Retirar /login_up.php e /login.php (Plesk) da raiz do domínio — mover o painel para host/porta separado ou restringir por IP.	Curto prazo (7 dias)
4	Manter o portal de resultados no Worklab sempre acessado por link HTTPS, com aviso claro de que a senha é pessoal e intransferível.	Curto prazo (7 dias)
5	Substituir o contato em Gmail por e-mail @dominio com política de uso e registro de acesso.	Médio prazo (30 dias)
6	Verificação mensal automatizada (HTTP→HTTPS, validade do certificado, disponibilidade do site) com alerta imediato.	Contínuo

5. O que a SHIELD entrega

Diagnóstico Express + laudo LGPD formal (documento com nome da empresa, severidade e plano) — R$ 497

Correção técnica (redirect HTTPS, certificado, retirada do painel da raiz) — R$ 400 a R$ 900, conforme acesso à hospedagem

Escudo Mensal (verificação mensal, alerta de certificado e de site fora do ar, WhatsApp direto) — R$ 297/mês

Este documento foi produzido exclusivamente a partir de informação pública, sem acesso a sistemas internos e sem tentativa de exploração. Testes ativos, correções e monitoramento exigem contrato e autorização por escrito do responsável.

Contato: Lorran Gustavo — SHIELD Cibersegurança — Ariquemes/RO — emitido em 21/10/2026 13:12